DevSecOps Pipeline Architecture & Failure Policy

Project: Geo-Bound Crypto-Vault — Student 4 Technical Specification

المشروع:	Encrypted-Vault	**المستودع (Repo):**	hadeelbasem515/Encrypted-Vault
المسار التقني:	.github/workflows/devsecops-pipeline.yml	**اسم الطالب:**	Hadeel Basim Salem Issa (الطالب 4)

1. الملخص التنفيذي وهندسة خط الأمان

يُنفذ خط عمليات الـ DevSecOps في مشروع **Encrypted-Vault** أتمتة شاملة لفحص أمان سلسلة التوريد البرمجية (Software Supply Chain Security) قبل إقرار أي كود. يعتمد النظام على GitHub Actions لتشغيل الفحوصات تلقائياً مع كل عملية Push أو Pull Request لضمان الموثوقية.

2. مراحل التشغيل التفصيلية (Workflow Stages)

يتكون خط البناء والأمان من 5 مراحل أساسية ومتتالية:

1. **Checkout Code:** سحب ونسخ أحدث نسخة من كود المشروع داخل حاوية التشغيل (Runner).
2. **Set up Python:** تهيئة بيئة تشغيل بايثون الإصدار `3.10` لتلائم متطلبات النظام.
3. **Security Vulnerability Scan (Trivy):** فحص ملفات ومجلدات المشروع لاكتشاف الثغرات العالية (CRITICAL & HIGH) مع تصفية الثغرات غير المثبتة لتقليل التشويش.
4. **Generate SBOM with Syft:** توليد وثيقة جرد المكونات البرمجية والتبعيات بصيغة `sbom.spdx.json`.
5. **Scan SBOM with Grype:** تحليل ملف الـ SBOM المولد للتحقق من عدم وجود ثغرات في المكتبات والتبعيات.

3. سياسة التعامل مع الثغرات وإدارة البناء (Gatekeeping Policy)

تم اعتماد وضع التدقيق والفحص (Audit Mode) مبدئياً باستخدام `continue-on-error: true` لضمان استمرار التشغيل واستخراج التقارير دون توقف مفاجئ:

مستوى الخطورة	نطاق درجة CVSS	إجراء التدقيق الحالي	إجراء سياسة الإنتاج (Production Gate)
CRITICAL	10.0 – 9.0	تسجيل وتنبيه (استمرار)	إيقاف البناء فوراً (Fail Build) وحظر النشر
HIGH	8.9 – 7.0	تسجيل وتنبيه (استمرار)	إيقاف البناء (إذا توفر حل للثغرة)
MEDIUM / LOW	6.9 – 0.1	تسجيل وتنبيه (استمرار)	السماح بالبناء مع إشعار للمطورين

4. الكود المعتمد لخط العمليات (Workflow YAML)

```
name: DevSecOps CI/CD Pipeline on: [push, pull_request] jobs: devsecops-pipeline: runs-on: ubuntu-latest steps: - uses: actions/checkout@v4 - uses: actions/setup-python@v5 with: { python-version: '3.10' } - uses: aquasecurity/trivy-action@master continue-on-error: true with: { scan-type: 'fs', severity: 'CRITICAL,HIGH' } - uses: anchore/sbom-action@v0 continue-on-error: true with: { path: '.', file: sbom.spdx.json } - uses: anchore/scan-action@v3 continue-on-error: true with: { sbom: sbom.spdx.json, severity-cutoff: high }
```